

Prepared by: Abdul Wahid
Document Type: Lab Report
Category: Web Application Vulnerability Assessment (Acunetix)

Executive Summary

This lab was conducted to evaluate the use of Acunetix, an automated web application vulnerability scanner, against Metasploitable 2 — a deliberately vulnerable Linux virtual machine commonly used for security training. The objective was to configure Acunetix, launch a full vulnerability scan against the target, and analyze the resulting findings.

The scan identified multiple high-severity vulnerabilities, resulting in an overall Threat Level 3 (High) rating. Key findings included PHP-CGI remote code execution, directory traversal, local file inclusion, cross-site scripting (XSS), configuration file disclosure, and insecure MySQL/MariaDB credential handling — all consistent with the known, intentionally vulnerable services bundled in Metasploitable 2 (DVWA, Mutillidae, and related test applications).

This report documents the scan configuration, execution, and findings, and concludes with remediation recommendations appropriate for a production environment.

Lab Environment

The table below documents the two machines used throughout this exercise.

Role	Machine / OS	IP Address	Purpose in Lab
Attacker	Kali Linux	192.168.100.140	Runs Acunetix; used to scan the victim machine for web application vulnerabilities.
Victim	Metasploitable 2	192.168.100.148	Deliberately vulnerable Linux VM hosting outdated web applications (DVWA, Mutillidae, phpinfo, etc.) used as the scan target.

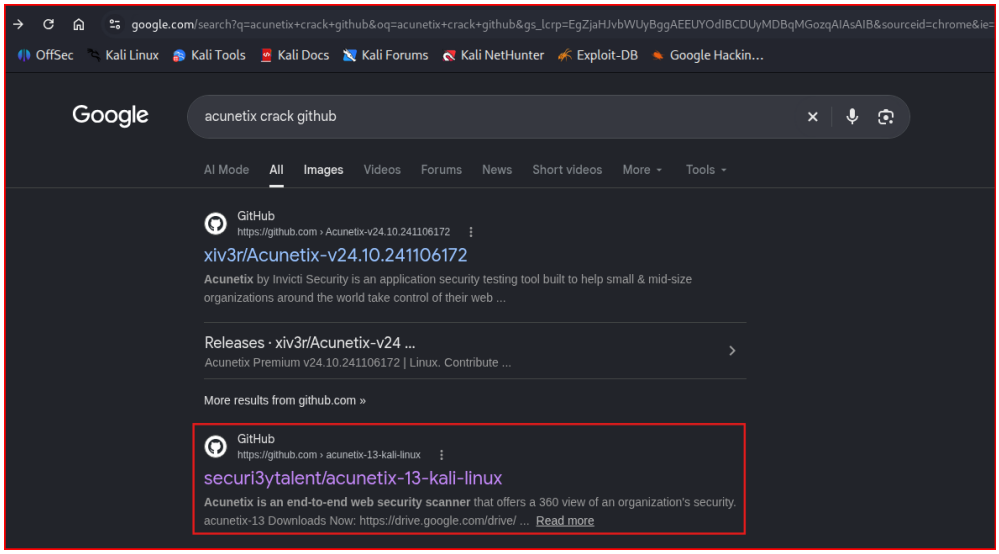
Tool Overview: Acunetix

What is Acunetix?

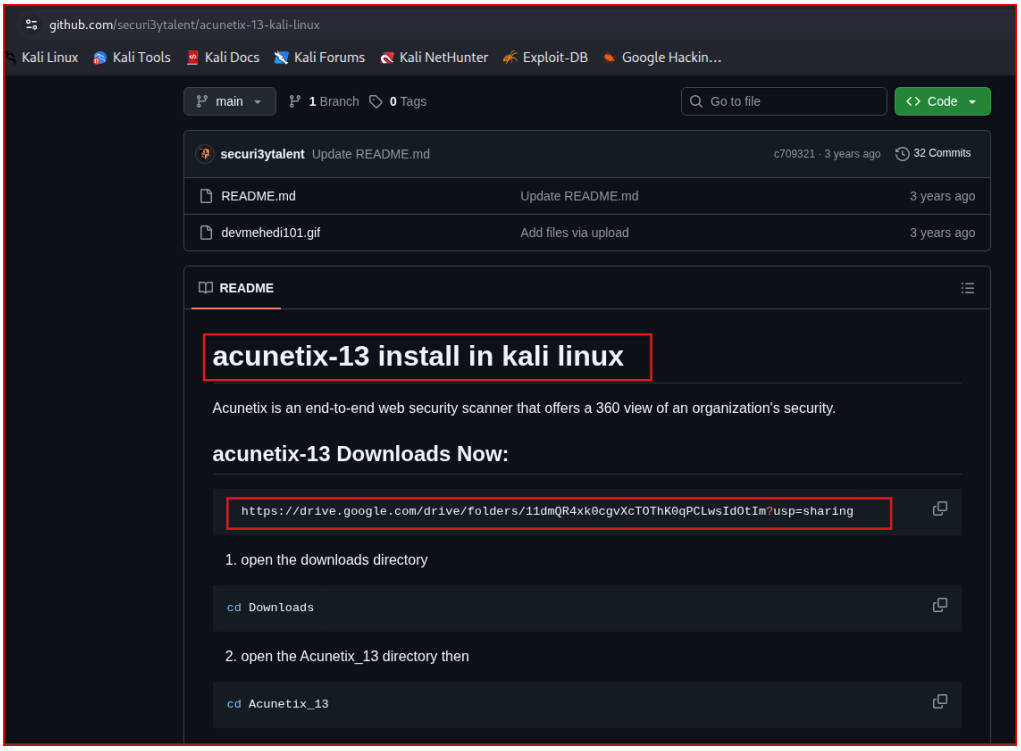
- Acunetix is an automated web application security scanner that identifies vulnerabilities such as SQL injection, cross-site scripting, and other common web security flaws.
- It assesses risk across a range of platforms and technologies, producing detailed reports with remediation guidance.
- It integrates with development and issue-tracking environments to support continuous security testing throughout the software development lifecycle.
- Regular use of Acunetix helps organizations meet compliance requirements by enabling repeatable, thorough vulnerability assessments of web-facing assets.
-

Launch & Setup Acunetix

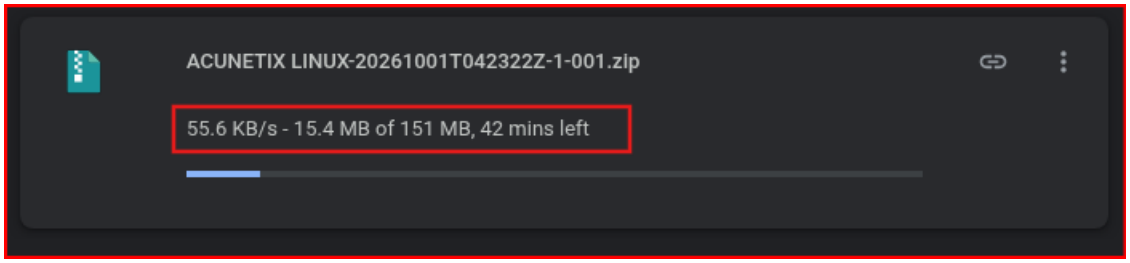
Open Browser & Search “acunetix crack github”



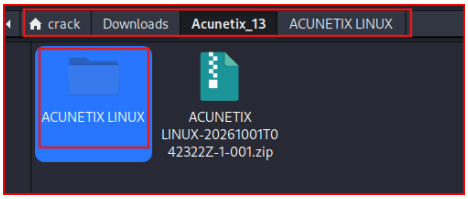
Copy the link & the installation will start



Wait until the download completes



Navigate to the Downloads & Unzip the File



Navigate to the Desired Directory
cd Downloads/Acunetix_13/ACUNETIX LINUX



Make the required files executable
chmod +x *

```
┌──(crack㉿kali)-[~/Downloads/Acunetix_13/ACUNETIX LINUX]
└─$ chmod +x *
```

Run the Acunetix installer
sudo bash ./acunetix_13.0.200217097_x64_.sh

```
┌──(crack㉿kali)-[~/Downloads/Acunetix_13/ACUNETIX LINUX]
└─$ sudo bash ./acunetix_13.0.200217097_x64_.sh

Acunetix Installer Version: v_200217097, Copyright (c) Acunetix
──────────────────────────────────────────────────────────────

Checking os ...
Checking for dependencies ...
Please read the following License Agreement. You must accept the terms of this
agreement before continuing with the installation.
press ENTER to continue
>>>
Product: Acunetix on-premises web vulnerability scanner and vulnerability management solution

END-USER LICENSE AGREEMENT

Definitions
"End-User License Agreement" ("EULA") or "License" means this End-User License Agreement.
"You", or "Licensee", or "End-User" means an individual or a single entity, corporate or other statut
```

Follow the installation prompts displayed in the terminal.
Accept the license (Yes)

```
35. Ownership, Intellectual Property Rights
This License does not convey to Licensee an interest in or
. No license or other right in or to the Product is granted
inform Acunetix Ltd of any suspected breach of Intellectual


Accept the license terms? [yes|no]
[no] >>> Yes
```

Enter Credentials
Username: crack
Email: 243699@students.au.edu.pk
Password: Admin123

```
By default the Acunetix will be installed to /home/acunetix/.acunetix

Checking database port ...
Checking backend port ...

Configuring hostname ...
Insert new hostname, or leave blank to use kali
    Hostname [kali]: crack

Configuring the master user ...
    Email: 243699@students.au.edu.pk
    Password:
    Password again:

Initializing file system ...
```

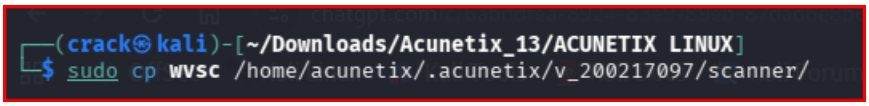
Acunetix is ready to go now

```
Generating certificates ...
 Generating certificate authority & certificates
Generating certificate authority
Certificate authority generation succesful
Generating certificate  ...
Certification generation succesful
Saving settings ...
Creating the startup script ...
Registering service ...
Created symlink '/etc/systemd/system/multi-user.target.wants/acunetix.service' → '/etc/systemd/system/acunetix.service'.

Adding LSR shortcuts ...
Creating uninstall ...

Please visit https://crack:3443/ to access Acunetix UI
```

Copy the scanner file
After the installation is completed, copy the wvsc file to the Acunetix scanner directory:
sudo cp wvsc /home/acunetix/.acunetix/v_200217097/scanner/



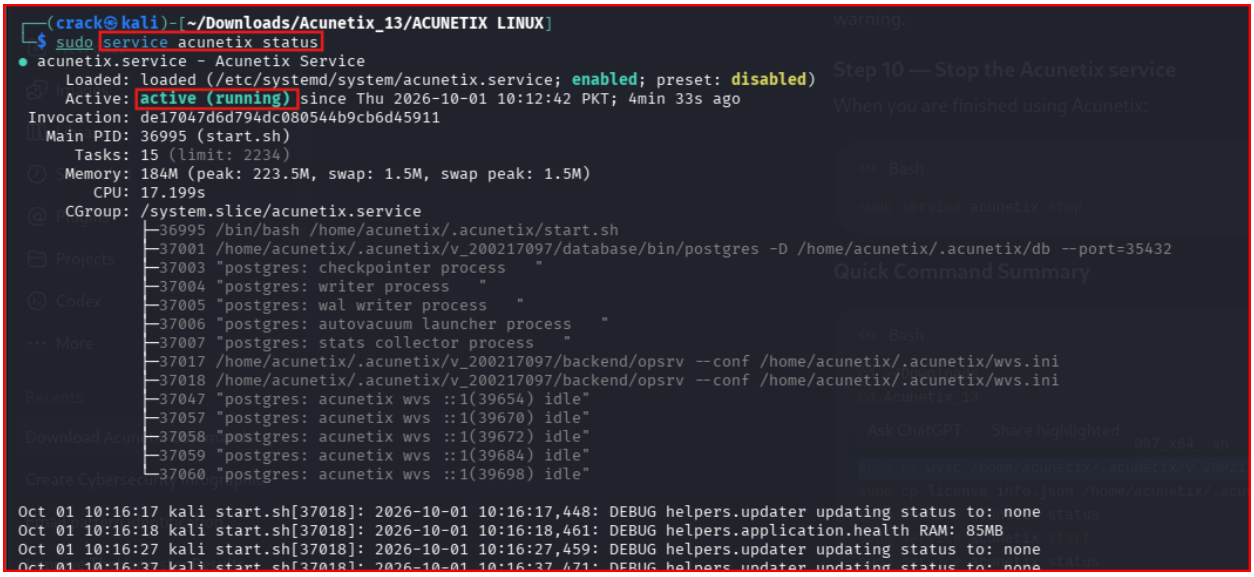
Copy license_info.json to the Acunetix license directory:
sudo cp license_info.json /home/acunetix/.acunetix/data/license/



Accessing the Acunetix Web Interface

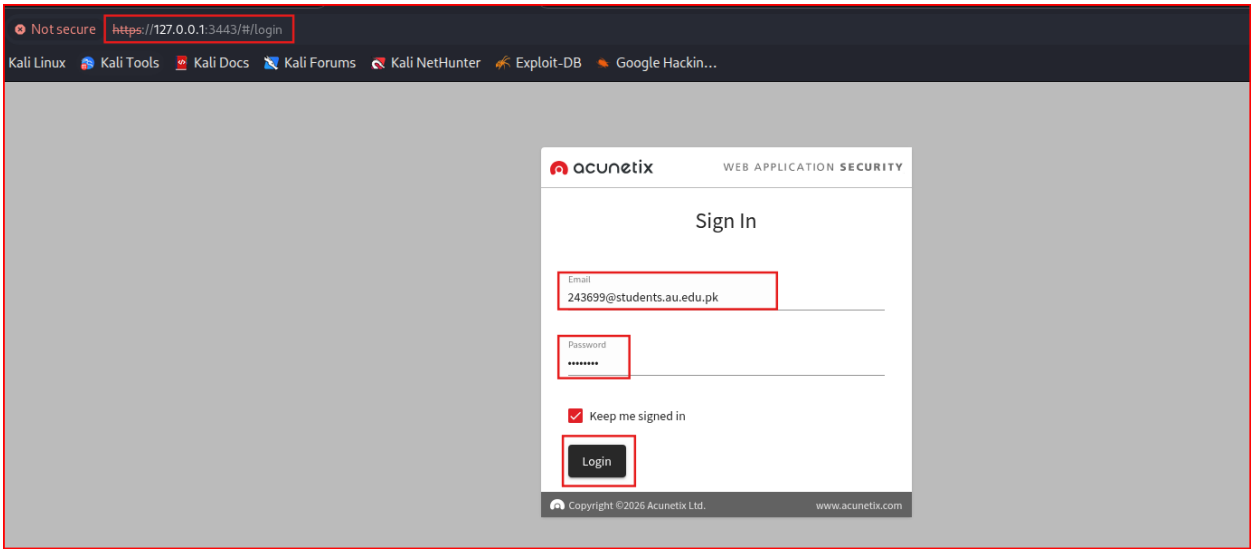
With Acunetix installed and the service running, its status can be verified using the command below.

```
sudo service acunetix status
```



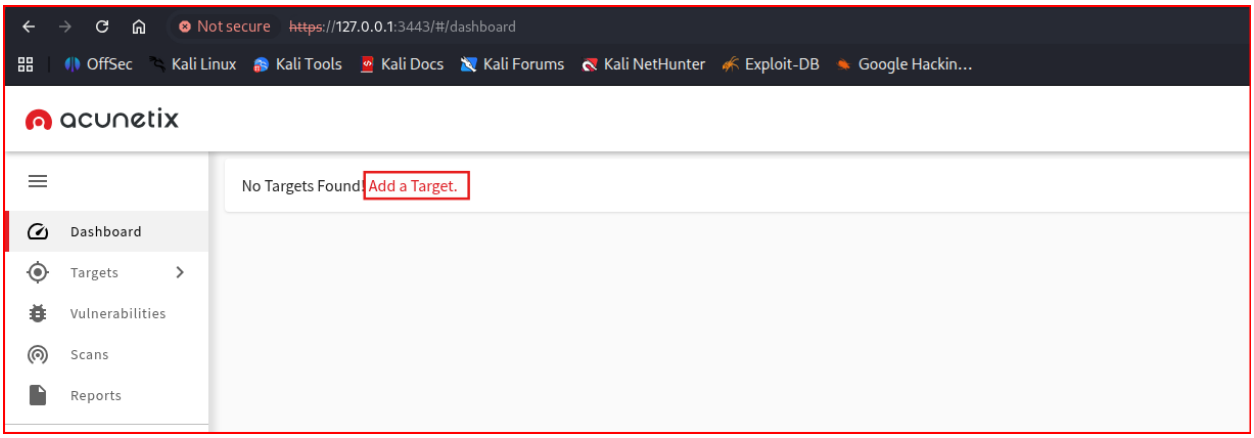
Acunetix exposes its management interface over HTTPS on port 3443. Because it uses a local, self-signed certificate, the browser will display a certificate warning the first time the page is loaded.

```
https://127.0.0.1:3443/
```



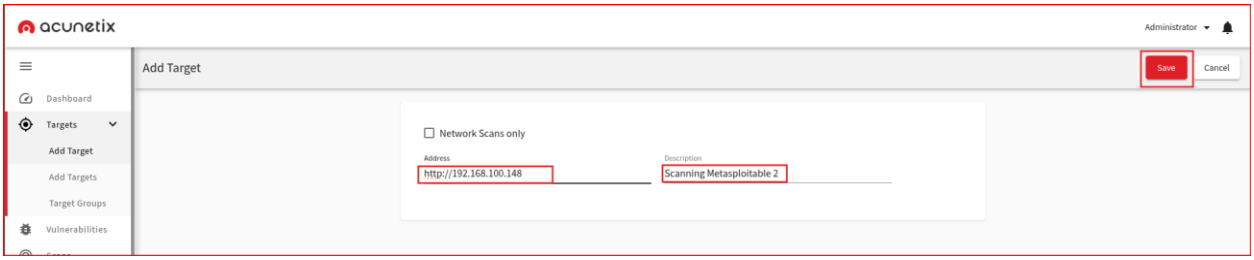
Specifying a Scan Target

On first login, the Acunetix dashboard shows no configured targets. A new target must be added before a scan can be run.



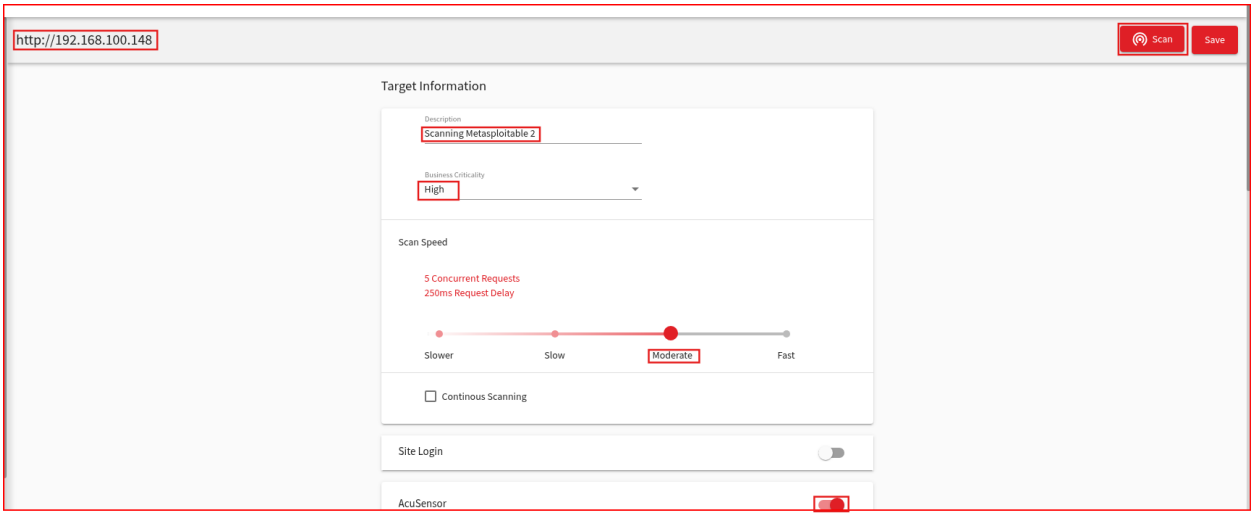
The target was added using the following details:

- Address: http://192.168.100.148
- Description: Scanning Metasploitable 2



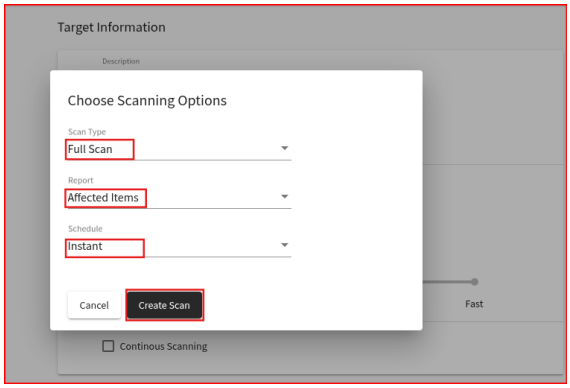
The target was then configured with the following scan parameters:

- Business Criticality: High
- Scan Speed: Moderate (5 concurrent requests, 250 ms request delay)
- AcuSensor: Enabled



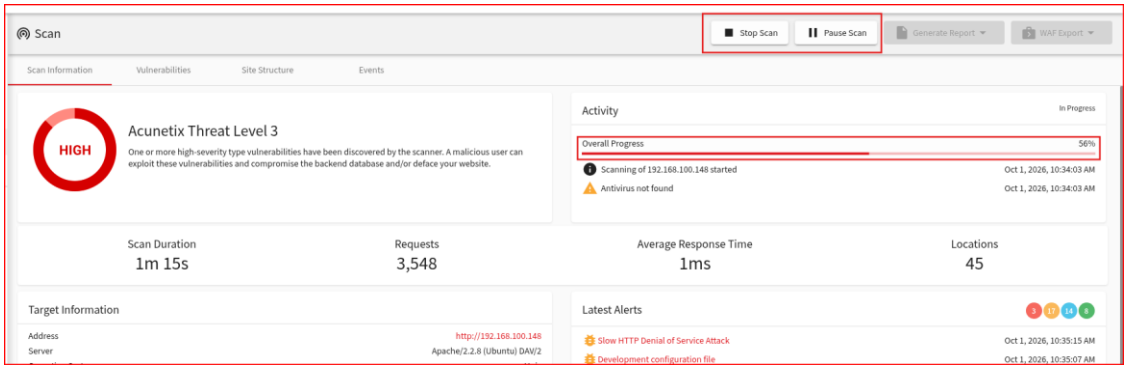
Before launching the scan, the scanning options were selected:

- Scan Type: Full Scan
- Report: Affected Items
- Schedule: Instant

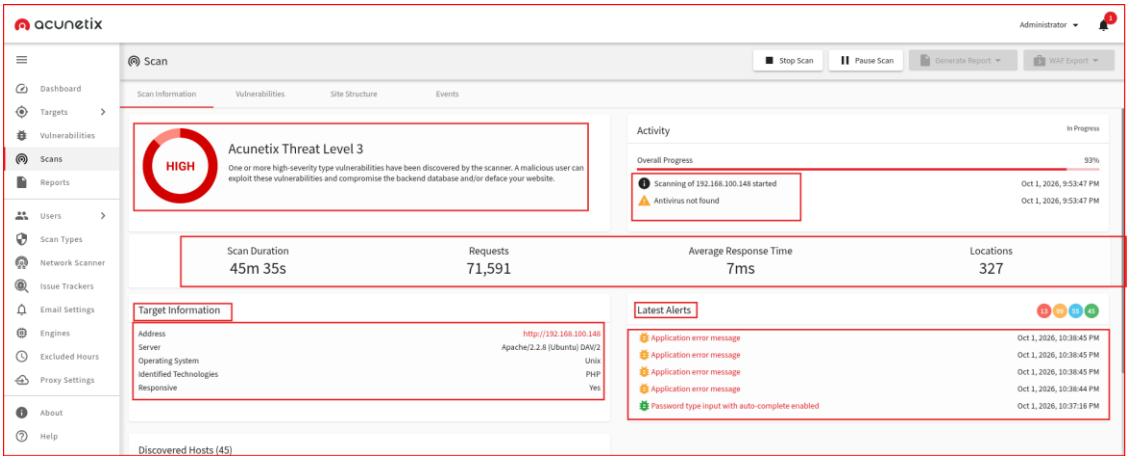


Scan Execution & Monitoring

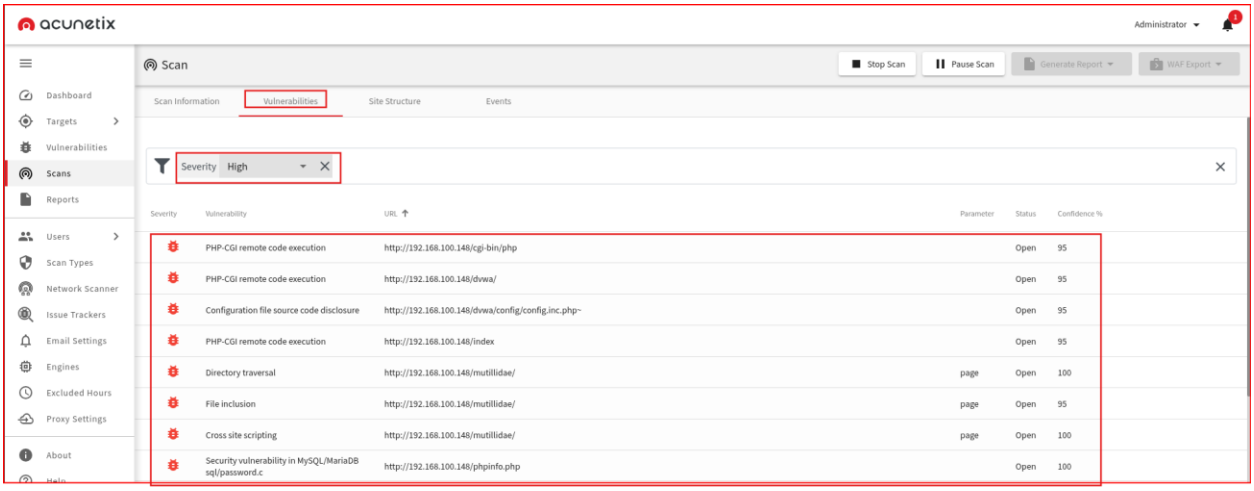
Once started, the scan dashboard displays real-time progress, including overall completion percentage, request count, average response time, and the number of discovered locations. Early in the scan, Acunetix already flagged the target with an Acunetix Threat Level 3 (High) rating.



As the scan continued, request counts and discovered locations increased substantially, with the scan ultimately covering 327 discovered locations and over 71,000 requests at this stage.



The Vulnerabilities tab was used to filter results by severity (High), surfacing the confirmed findings below.



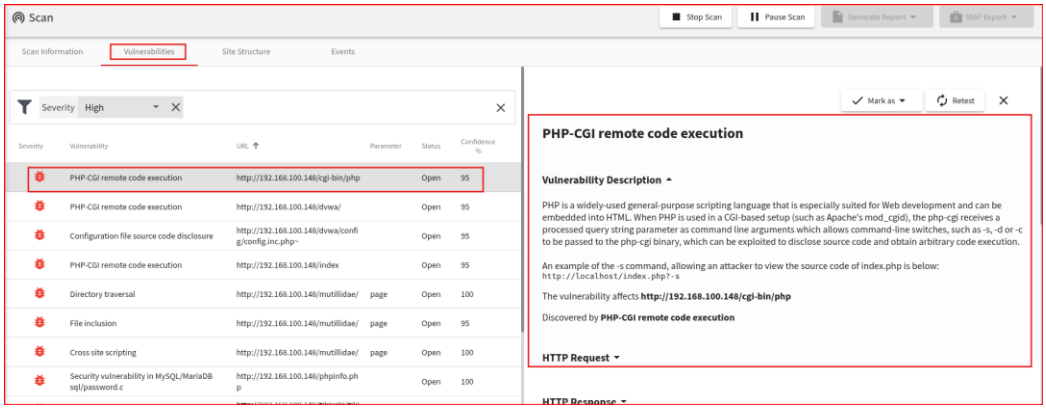
Vulnerability Findings

The table below summarizes the high-severity vulnerabilities identified during the scan.

Severity	Vulnerability	Affected URL	Status
High	PHP-CGI remote code execution	/cgi-bin/php	Open
High	PHP-CGI remote code execution	/dvwa/	Open
High	Configuration file source code disclosure	/dvwa/config/config.inc.php~	Open
High	PHP-CGI remote code execution	/index	Open
High	Directory traversal	/mutillidae/ (param: page)	Open
High	File inclusion	/mutillidae/ (param: page)	Open
High	Cross-site scripting	/mutillidae/ (param: page)	Open
High	Security vulnerability in MySQL/MariaDB	/phpinfo.php (param: sql/password)	Open

Detailed Vulnerability Analysis — PHP-CGI Remote Code Execution

Selecting an individual finding in the Vulnerabilities tab opens a detail panel describing the issue, its HTTP request/response evidence, and an example proof-of-concept.



Impact of this vulnerability:

A remote, unauthenticated attacker could obtain sensitive information, cause a denial-of-service condition, or execute arbitrary code with the privileges of the web server.

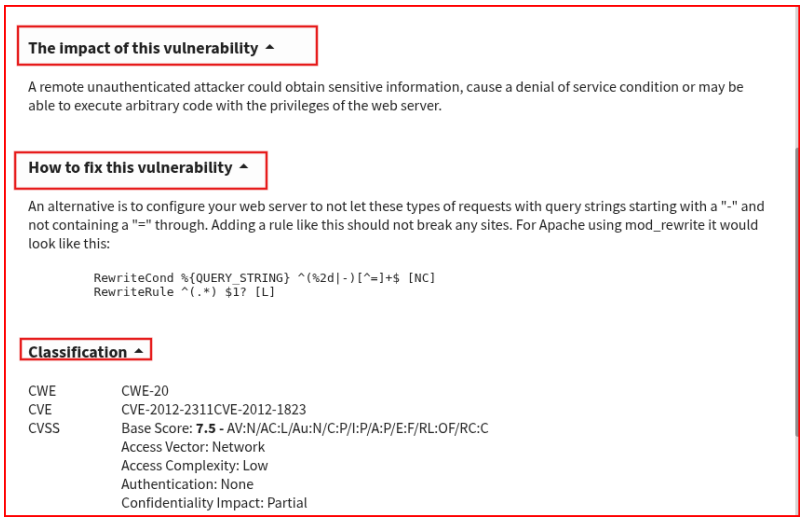
How to fix this vulnerability:

Configure the web server to reject requests with query strings that start with a hyphen and do not contain an equals sign. For Apache using mod_rewrite, this can be implemented as follows:

```
RewriteCond %{QUERY_STRING} ^(%2d|-)[^=]+$ [NC] RewriteRule ^(.*) $1? [L]
```

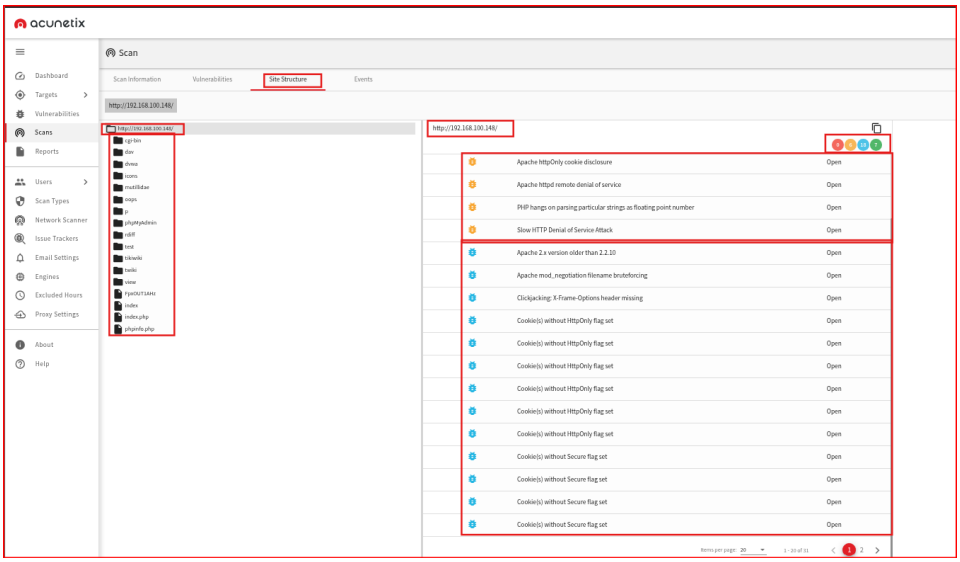
Classification:

- CWE: CWE-20
- CVE: CVE-2012-2311, CVE-2012-1823
- CVSS Base Score: 7.5 (AV:N / AC:L / Au:N / C:P / I:P / A:P)
- Access Vector: Network | Access Complexity: Low | Authentication: None | Confidentiality Impact: Partial

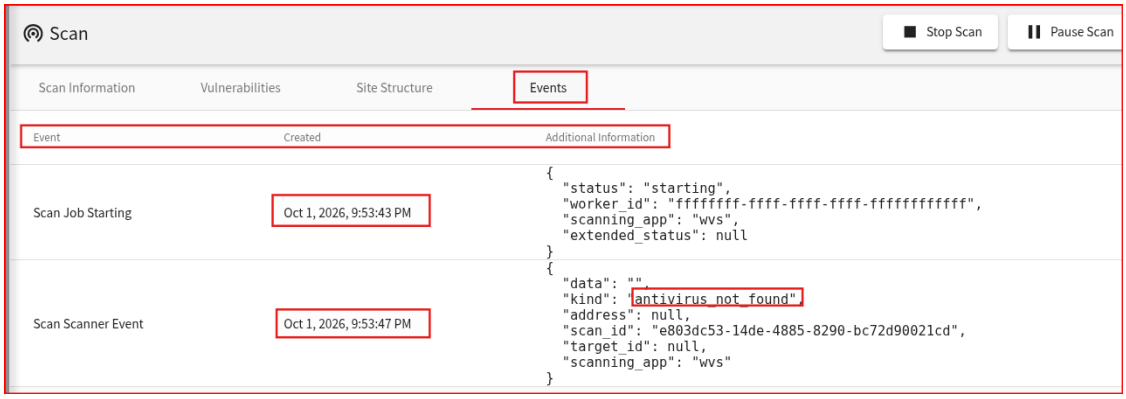


Site Structure & Scan Events

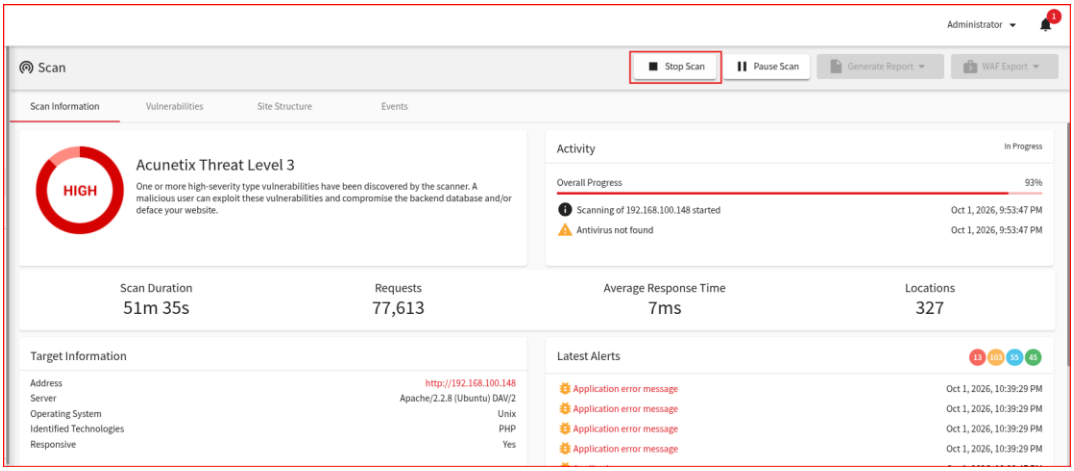
The Site Structure tab maps the discovered directories and files on the target, alongside a per-node summary of issue counts by severity.



The Events tab records scan lifecycle events in JSON form, including scan start time and scanner status messages such as 'antivirus_not_found'.

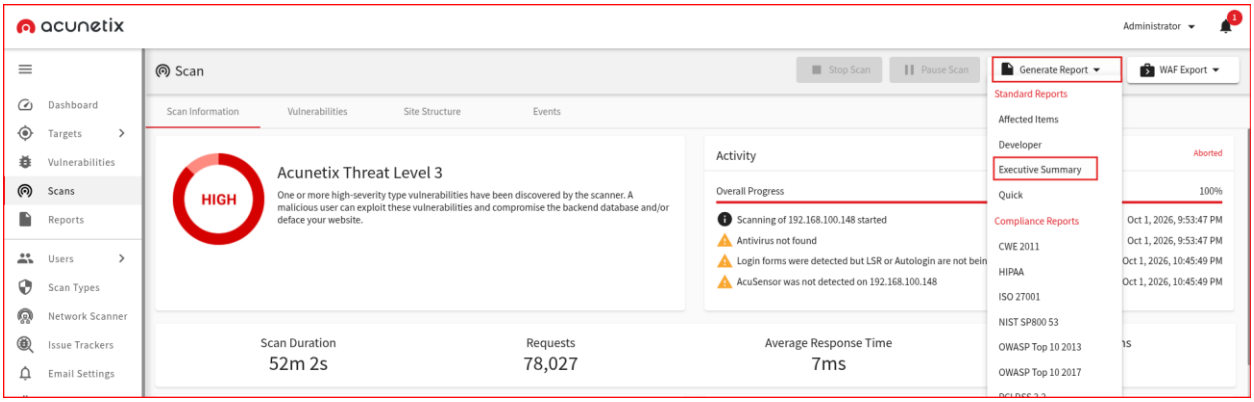


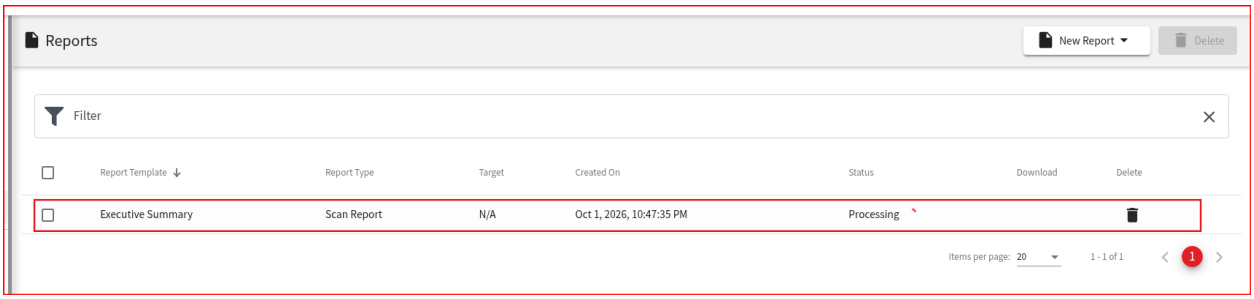
At completion, the scan reported a final duration of 51 minutes 35 seconds across 77,613 requests, continuing to confirm the Threat Level 3 (High) rating along with identified server details (Apache/2.2.8 Ubuntu, Unix, PHP).



Report Generation

Once the scan completed, an Executive Summary report was generated from the Scan view's Generate Report menu, alongside other available templates (Affected Items, Developer, Quick, and various compliance-mapped reports such as OWASP Top 10, CWE 2011, HIPAA, and ISO 27001).





Conclusion

This lab demonstrated a complete automated web application vulnerability assessment workflow using Acunetix against Metasploitable 2. The scan confirmed multiple high-severity, well-known vulnerabilities — including PHP-CGI remote code execution, directory traversal, local file inclusion, cross-site scripting, and insecure database credential exposure — consistent with the intentionally vulnerable applications hosted on the target.

Key takeaways from the exercise:

- Automated scanners like Acunetix can rapidly surface a broad range of vulnerability classes across a large application surface, as reflected in the thousands of requests and hundreds of discovered locations in this scan.
- Business criticality and scan speed settings should be tuned to the environment — higher speeds increase load on the target and may affect availability in sensitive environments.
- Enabling AcuSensor provides deeper, code-level insight when supported, improving the accuracy of findings beyond black-box testing alone.
- Findings should always be triaged individually; the detail panel (impact, fix, CWE/CVE/CVSS classification) is essential for prioritizing remediation.

Recommended remediation:

- Patch or upgrade PHP-CGI to a version not affected by CVE-2012-2311 / CVE-2012-1823, or restrict/disable CGI-based PHP execution entirely.
- Remove backup/temporary configuration files (e.g., config.inc.php~) from web-accessible directories.
- Apply input validation and output encoding to remediate directory traversal, file inclusion, and cross-site scripting findings in the affected application (Mutillidae).
- Restrict or remove publicly accessible diagnostic pages such as phpinfo.php, and ensure database credentials are never exposed via such pages.
- Re-scan after remediation to confirm each finding has been resolved before considering the environment production-ready.